

Clase 085 — Reporte profesional de pentest

Parte: **3 — Hacking ético y pentesting: metodología** · Fuente: *Penetration Testing* (Weidman) · PTES — *Reporting* · CVSS v3.1/v4.0 (FIRST) 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

Aprender a convertir un engagement técnico en un **entregable de valor**: un informe que la dirección entiende y el equipo técnico puede accionar. El reporte es el producto final por el que paga el cliente; un hallazgo brillante mal comunicado no se arregla nunca. Cubrimos estructura, priorización por riesgo (CVSS + contexto de negocio), evidencia reproducible y recomendaciones accionables.

📄 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Estructurar** un informe profesional con resumen ejecutivo, metodología, hallazgos y anexos.
- 2. **Escribir** un resumen ejecutivo orientado a negocio, sin jerga, en menos de una página.
- 3. **Puntuar** vulnerabilidades con CVSS y **ajustar** la prioridad al contexto del cliente (activo crítico vs entorno de pruebas).
- 4. **Documentar** cada hallazgo con impacto, evidencia reproducible, y remediación priorizada.
- 5. **Evitar** los errores que restan credibilidad: falsos positivos, capturas ilegibles, recomendaciones genéricas.

📖 Temas

#	Tema	Por qué importa
1	Anatomía del informe	Cada sección tiene un lector distinto.
2	Resumen ejecutivo	Es lo único que leerá la dirección.
3	Puntuación de riesgo (CVSS + negocio)	Priorizar mal desperdicia el presupuesto de remediación.
4	Estructura de un hallazgo	Título, riesgo, impacto, evidencia, remediación, referencias.
5	Evidencia reproducible	Sin pasos claros, el cliente no puede verificar ni corregir.
6	Remediación accionable	El objetivo real del pentest es que se arregle.
7	Retest y cierre	Confirmar que las correcciones funcionan.

📖 Definiciones y características

Resumen ejecutivo : Sección de 1 página para la dirección: postura general de riesgo, hallazgos clave en lenguaje de negocio y recomendación estratégica. Característica clave: **sin jerga técnica** ni comandos.

CVSS (Common Vulnerability Scoring System) : Estándar de la FIRST para puntuar la severidad (0–10). Da una base objetiva, pero debe **ajustarse** con el contexto (exposición real, valor del activo, controles compensatorios).

Hallazgo (finding) : Unidad del informe que describe una debilidad concreta. Característica clave: es *autocontenido* — se entiende sin leer el resto del documento.

Evidencia reproducible : Pasos, comandos y capturas que permiten al cliente **reproducir y verificar** el hallazgo. Sin ella, un hallazgo es una afirmación no comprobable.

Retest : Verificación posterior de que las remediaciones aplicadas cierran efectivamente los hallazgos reportados.

Herramientas y preparación

Una plantilla de informe (Markdown/LaTeX/Word), un sistema para gestionar hallazgos (incluso una hoja de cálculo con CVSS), la calculadora CVSS de FIRST y las capturas/logs recopilados durante el engagement. Opcional: herramientas de reporting como Dradis o PlexTrac para equipos.

Laboratorio guiado

Ejercicio de redacción a partir de un hallazgo de laboratorio (p. ej., una SQLi encontrada en tu propia instancia de DVWA en clases previas).

1. **Redacta el resumen ejecutivo.** Una página, sin jerga: ¿cuál es el riesgo para el negocio? ¿qué tres cosas debe hacer la dirección?
2. **Describe la metodología.** Alcance, ventana temporal, enfoque (caja negra/gris/blanca), limitaciones.
3. **Documenta un hallazgo completo** usando esta estructura: - **Título** claro (p. ej. "Inyección SQL en el login permite acceso no autenticado"). - **Severidad**: calcula el vector CVSS y ajústalo (¿el activo es crítico? ¿está expuesto a internet?). - **Impacto de negocio**: qué pasaría si se explota (fuga de datos de clientes, etc.). - **Evidencia reproducible**: petición/comando exacto + captura legible. - **Remediación**: consultas parametrizadas, WAF como mitigación temporal, referencia OWASP. - **Referencias**: OWASP, CWE.
4. **Prioriza.** Ordena una lista de 5 hallazgos ficticios por riesgo real (no solo por CVSS bruto).
5. **Define el retest.** Especifica cómo se verificará que cada corrección funcionó.
6. **Revisa la calidad.** Verifica que no queden falsos positivos, que las capturas sean legibles y que cada recomendación sea específica.

Ejercicios

1. Escribe un resumen ejecutivo de 200 palabras para una audiencia no técnica a partir de 3 hallazgos.
2. Calcula el CVSS v3.1 de una SQLi no autenticada expuesta a internet y justifica cada métrica.
3. Reescribe una recomendación genérica ("mejorar la seguridad") en una accionable y específica.
4. Toma una captura de pantalla de una prueba y anótala (resaltar el dato clave) para que sea autoexplicativa.
5. Diseña la tabla resumen de hallazgos (título, severidad, estado) para la primera página técnica.

Reto verificable

Redacta un mini-informe (resumen ejecutivo + 2 hallazgos completos + tabla de priorización) sobre vulnerabilidades encontradas en tu propio laboratorio.

Criterio de aceptación: el resumen ejecutivo no contiene jerga técnica; cada hallazgo tiene CVSS justificado, evidencia reproducible y remediación específica con referencia; la priorización considera contexto de negocio, no solo el número CVSS.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Resumen ejecutivo lleno de comandos y CVEs	La dirección no lo entiende. Reescríbelo en lenguaje de impacto de negocio.
Pegar la salida cruda de un escáner como "hallazgos"	Genera falsos positivos y desconfianza. Valida y contextualiza cada uno manualmente.
Capturas ilegibles o sin anotar	El cliente no ve el punto. Recorta, resalta y explica cada evidencia.
Recomendaciones genéricas	"Aplicar parches" no ayuda. Sé específico: qué versión, qué configuración, qué línea.
Priorizar solo por CVSS bruto	Un CVSS 9 en un entorno aislado importa menos que un 6 en el core expuesto. Ajusta al contexto.
No planificar el retest	Sin verificación, no sabes si el riesgo se cerró. Inclúyelo en el alcance.

Preguntas frecuentes

? ¿Qué es lo más importante del informe? El resumen ejecutivo y la calidad/priorización de los hallazgos. Es lo que decide si la organización actúa.

? ¿CVSS es suficiente para priorizar? No. Es una base objetiva, pero hay que ajustarla con exposición real, valor del activo y controles compensatorios del cliente.

? ¿Debo incluir los hallazgos "informativos" o de bajo riesgo? Sí, en un anexo. Aportan valor sin inflar la lista crítica, y muestran la profundidad del trabajo.

? ¿El informe es el final del engagement? Casi. Suele haber una reunión de presentación y, tras la remediación, un **retest** para confirmar el cierre de los hallazgos.

Referencias

- PTES — [Reporting](#)
- FIRST — [CVSS Specification & Calculator](#)
- Weidman, G. — *Penetration Testing*, capítulo de reporting.
- OWASP — [Web Security Testing Guide \(WSTG\) — Reporting](#)

Siguiente clase

Clase 086 - Arquitectura web moderna y superficie de ataque